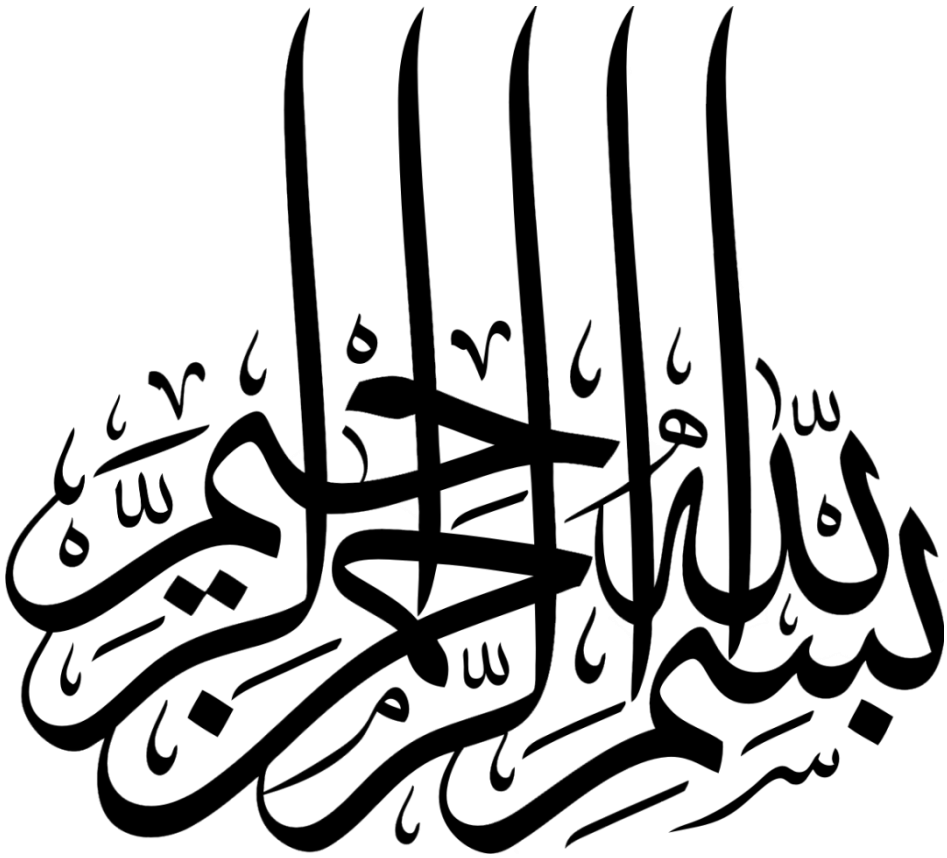


گزارش آزمون نفوذپذیری

سامانه fanava.aqdasiyehstone

شرکت فناوران طلوع شبکه **محرمانه** **1404/06/31**

Toluo_fanava.aqdasiyehstone_PentestReport


بسم الله الرحمن الرحيم

فهرست مطالب

عنوان | صفحه

فصل 1- مقدمه و خلاصه نتایج 4

1-1- دسته کلاس‌های آزمون نفوذ 5

1-2- محاسبه شدت آسیب‌پذیری‌ها 5

1-3- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون 6

1-3-1- شناسایی وب‌سرور 6

1-3-2- بررسی سرویس‌های امنیتی 10

1-4- خلاصه مدیریتی 11

فصل 2- تشریح آسیب‌پذیری‌های کشف شده 13

2-1- آسیب‌پذیری Vulnerability of Plugins – No Update 13

2-2- آسیب‌پذیری Account Enumeration and Guessable User Account 15

2-3- آسیب‌پذیری Weak Lock Out Mechanism 18

2-4- آسیب‌پذیری Bypass Rate Limit 19

2-5- آسیب‌پذیری WordPress Default Page 21

2-6- آسیب‌پذیری Information Disclosure 23

2-7- عدم استفاده از Security Headers 24

2-7-1- Nginx Version Disclosure 25

فصل 1– مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز درجایگاه مهمی‌قرار می‌گیرد.

در صورتی که هیچ گونه محافظتی از این دارایی‌ها به عمل نیاید، امکان آسیب به آن از طرق مختلف متصور خواهد بود. البته وجود ابزارهای امنیتی مانند فایروال، آنتی ویروس، سیستم‌های تشخیص نفوذ و غیره، در این زمینه بسیار مفید هستند ولی وجود این ابزارها به تنهایی منجر به برقراری امنیت نمی‌شود. چرا که در خیلی از موارد مشاهده شده که حتی با وجود ابزارهای امنیتی مذکور، باز هم دسترسی به دارایی‌های سازمان توسط نفوذگران انجام شده است.

یکی از انواع خدماتی که در زمینه امنیت به شما در شناسایی و رفع مشکلات امنیتی کمک شایانی می‌نماید، تست نفوذ و ارزیابی امنیتی می‌باشد.

در فرآیند تست نفوذ سعی می‌شود تا آسیب‌پذیری‌های موجود در دارایی‌های شرکت یا سازمان، شناسایی شده و با ارائه راهکار رفع آن، آسیب‌پذیری موجود برطرف گردد.

مستند پیش‌رو، گزارش آزمون نفوذپذیری سامانه fanava.aqdasiyehstoneاست که توسط شرکت "فناوران طلوع شبکه" تدوین شده است.

1-1- دسته کلاس‌های آزمون نفوذ

متخصصان ارزیابی امنیتی و آزمون نفوذ شرکت «فناوران طلوع شبکه» با استفاده از متدولوژی‌ها و استانداردهای مختلف در حوزه برنامه‌های کاربردی تحت وب، مانند Web Security Testing Guide مربوط به OWASP در ترکیب با تجربه عملی خود در آزمون نفوذپذیری برنامه‌های کاربردی تحت وب در حوزه‌های مختلف اقدام به آزمون نفوذپذیری این سامانه‌ها می‌نمایند.

دسته کلاس‌های مورد آزمون برای برنامه‌های کاربردی تحت وب به صورت زیر طراحی شده است:

1. جمع‌آوری اطلاعات
2. آزمون پیکربندی و مدیریت استقرار
3. آزمون مدیریت هویت
4. آزمون تصدیق اصالت
5. آزمون مجازشماری
6. آزمون مدیریت نشست
7. آزمون اعتبارسنجی ورودی‌ها
8. آزمون مدیریت خطاها
9. آزمون رمزنگاری
10. آزمون منطق کسب‌وکار
11. آزمون سمت کاربر

1-2- محاسبه شدت آسیب‌پذیری‌ها

شدت یک آسیب‌پذیری با الهام از سیستم نمره‌دهی CVSS v3.1 محاسبه خواهد شد، که راهنمای آن در جدول زیر آورده شده است.

Severity	Score Range
Critical	**9.0 – 10.0**
High	**7.0 – 8.9**
Medium	**4.0 – 6.9**
Low	**0.1 – 3.9**

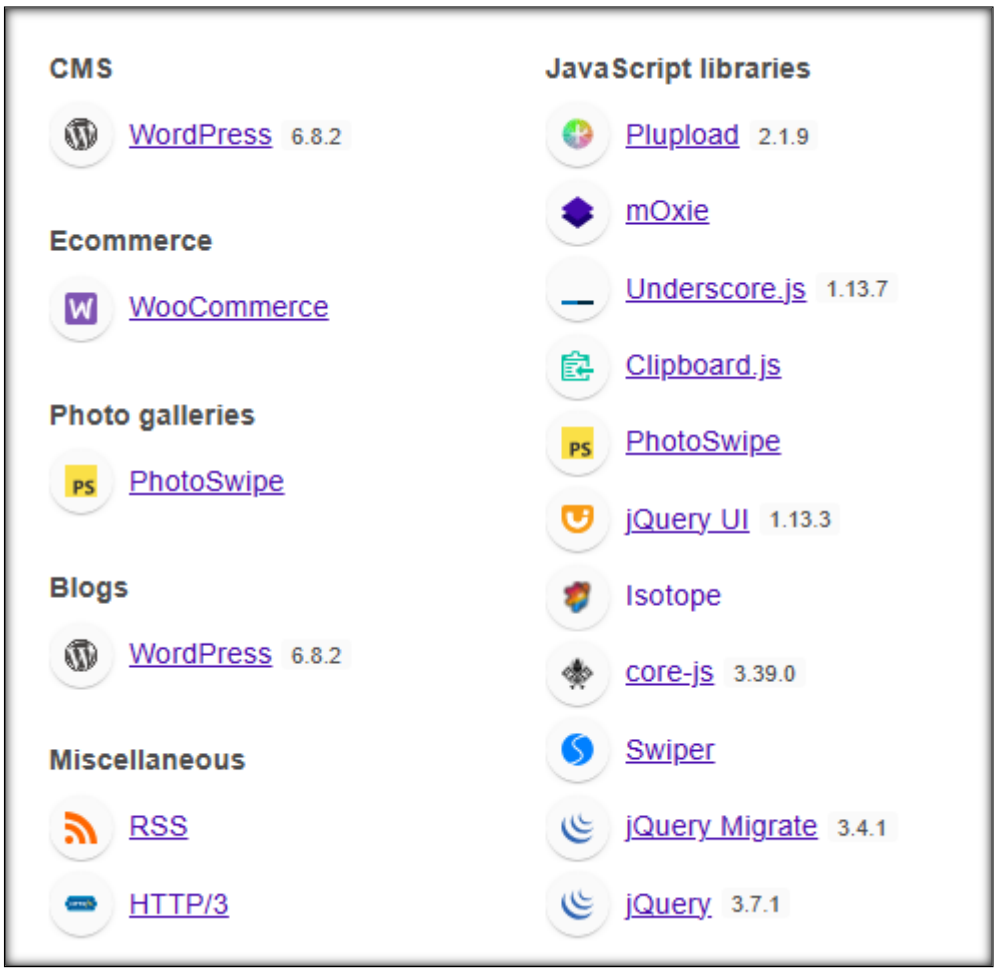
1-3- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

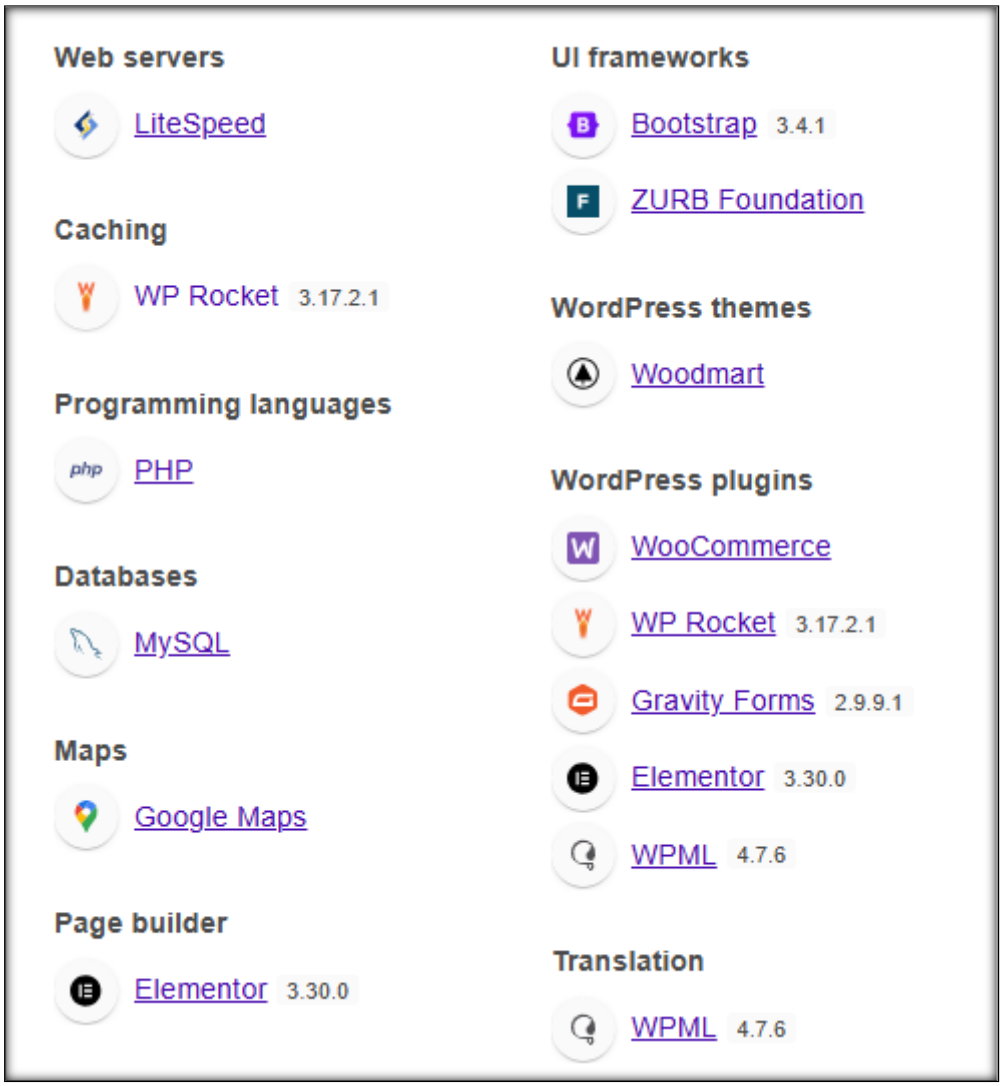
1-3-1- شناسایی وب‌سرور

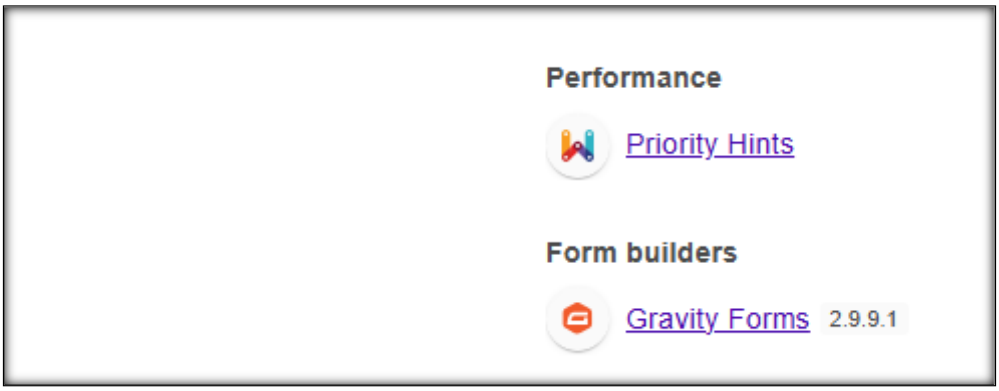
در صورت امکان، شناسایی وب‌سرور جزو وظایف حیاتی برای نفوذگر است. دانستن نسخه و نوع وب‌سرور، به نفوذگران اجازه می‌دهد تا آسیب‌پذیری‌های شناخته‌شده و روش‌های بهره‌برداری از آن‌ها را مشخص و در طول آزمون از آنها استفاده کنند. بنابراین، هدف این نوع آزمون، یافتن نسخه و نوع وب‌سرور برای تعیین آسیب‌پذیری‌های شناخته‌شده و روش‌های مناسب بهره‌برداری از آنها در طول ارزیابی است.

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

با بررسی هدرها، کوکی‌ها و اسامی فیلدهای مختلف سامانه و با استفاده از ابزارهایی از قبیل Wappalyzer، اطلاعات زیر درباره تکنولوژی‌های استفاده‌شده در سامانه هدف استخراج شد:




Web servers
LiteSpeed
Caching
WP Rocket 3.17.2.1
Programming languages
PHP
Databases
MySQL
Maps
Google Maps
Page builder
Elementor 3.30.0
UI frameworks
Bootstrap 3.4.1
ZURB Foundation
WordPress themes
Woodmart
WordPress plugins
WooCommerce
WP Rocket 3.17.2.1
Gravity Forms 2.9.9.1
Elementor 3.30.0
WPML 4.7.6
Translation
WPML 4.7.6

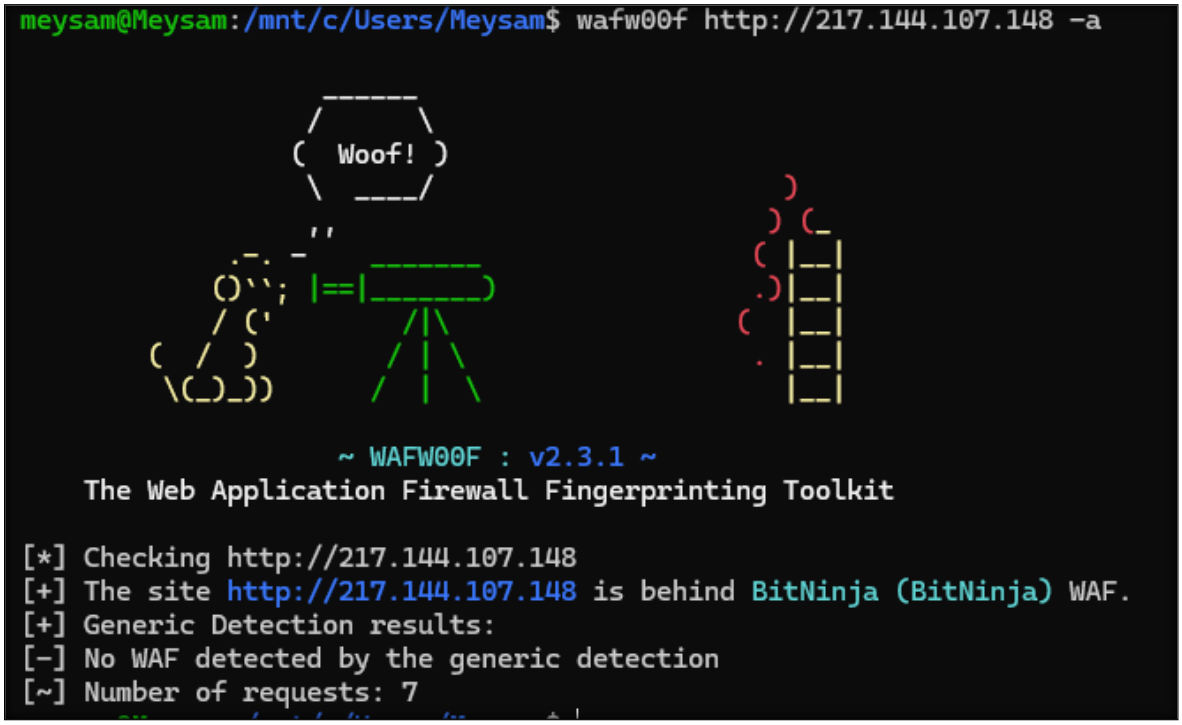

Performance
Priority Hints
Form builders
Gravity Forms
2.9.9.1

سامانه هدف با آدرس https://fanava.aqdasiyehstone.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



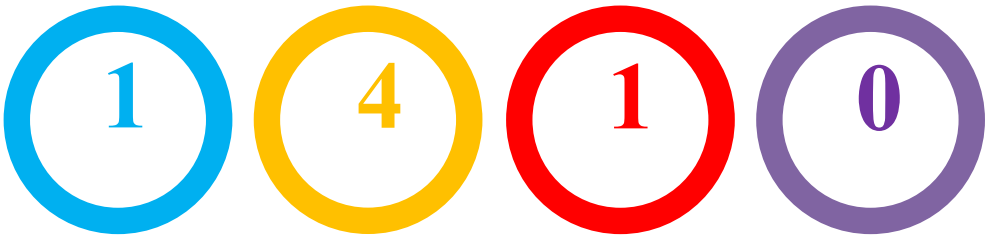
2-1-3- بررسی سرویس‌های امنیتی

با توجه به بررسی‌های انجام شده، مکانیزم امنیتی خاصی به منظور جلوگیری از حملات و بررسی درخواست‌های مخرب، در سامانه مشاهده نگردید. تصویر زیر نمایانگر این موضوع می‌باشد:



1-4- خلاصه مدیریتی

بررسی‌های انجام شده بر روی سامانه نمایانگر این موضوع است که وضعیت کلی سامانه fanava.aqdasiyehstone در وضعیت ریسک متوسط قرار دارد. البته مورد با سطح ریسک بالا شناسایی شده مربوط به عدم بروزرسانی پلاگین‌های وردپرس بوده و با رفع مشکلات موجود در این بخش، اغلب موارد مرتفع می‌گردد. همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.



در جدول زیر، تعداد آسیب‌پذیری‌هایی که روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک هر کدام، آورده شده‌اند:

ردیف	سامانه هدف	تعداد آسیب‌پذیری‌ها			
		آسیب‌پذیری‌های با ریسک بحرانی	آسیب‌پذیری‌های با ریسک بالا	آسیب‌پذیری‌های با ریسک متوسط	آسیب‌پذیری‌های با ریسک کم
1	https://fanava.aqdasiyehstone.com	0	1	4	1

به‌علاوه، عناوین آسیب‌پذیری‌هایی که بر روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک آن‌ها به‌صورت زیر است.

لازم به ذکر است که موارد مشخص شده در ادامه گزارش، به صورت نمونه بوده و آسیب‌پذیری‌ها می‌بایست در کل سامانه مرتفع گردند.

نام	درجه اهمیت
Vulnerability of Plugins – No Update	زیاد
Account Enumeration and Guessable User Account	متوسط
Weak Lock Out Mechanism	متوسط
Rate Limit	متوسط
WordPress Default Page	کم
Information Disclosure	کم
Security Headers	کم

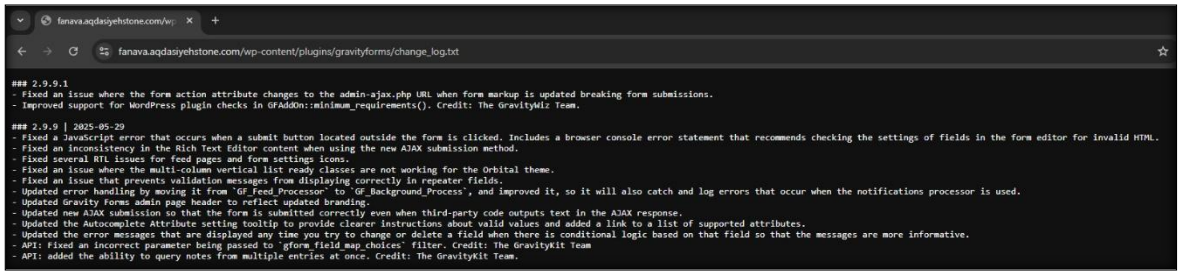
فصل 2– تشریح آسیب‌پذیری‌های کشف شده

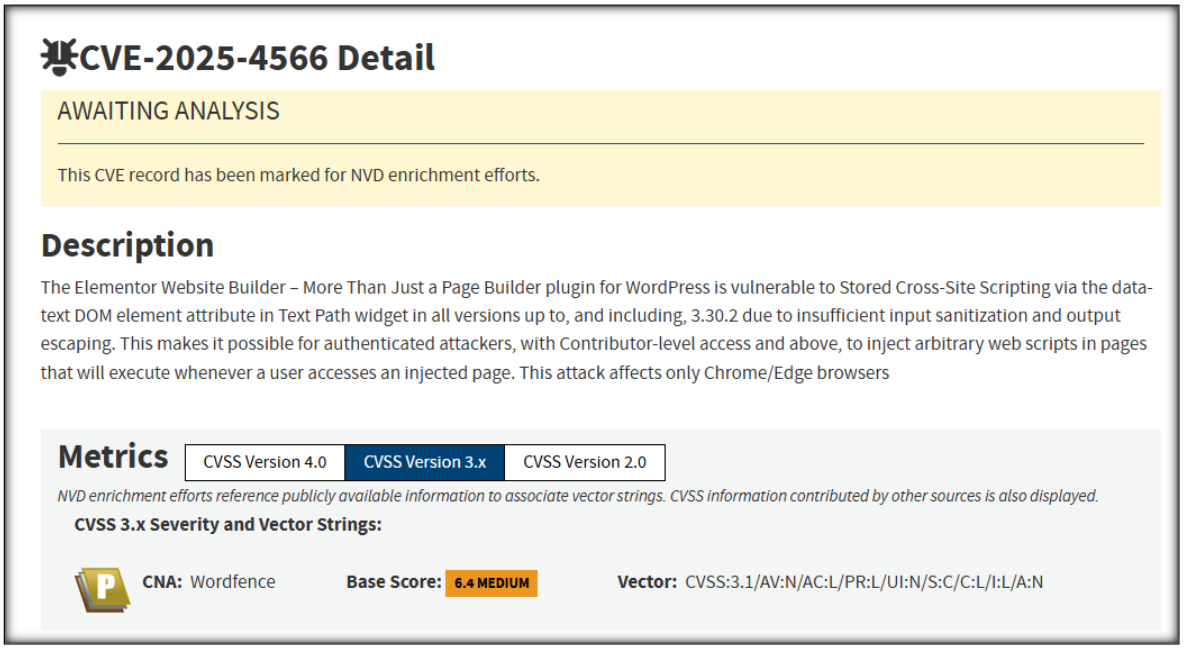
در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

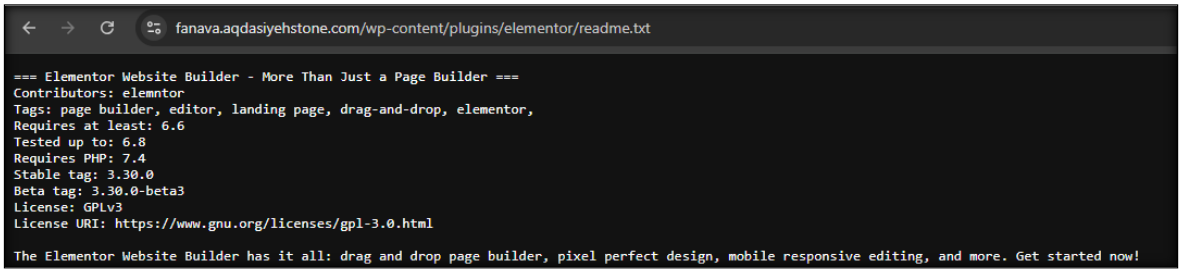
2-1- آسیب‌پذیری Vulnerability of Plugins – No Update

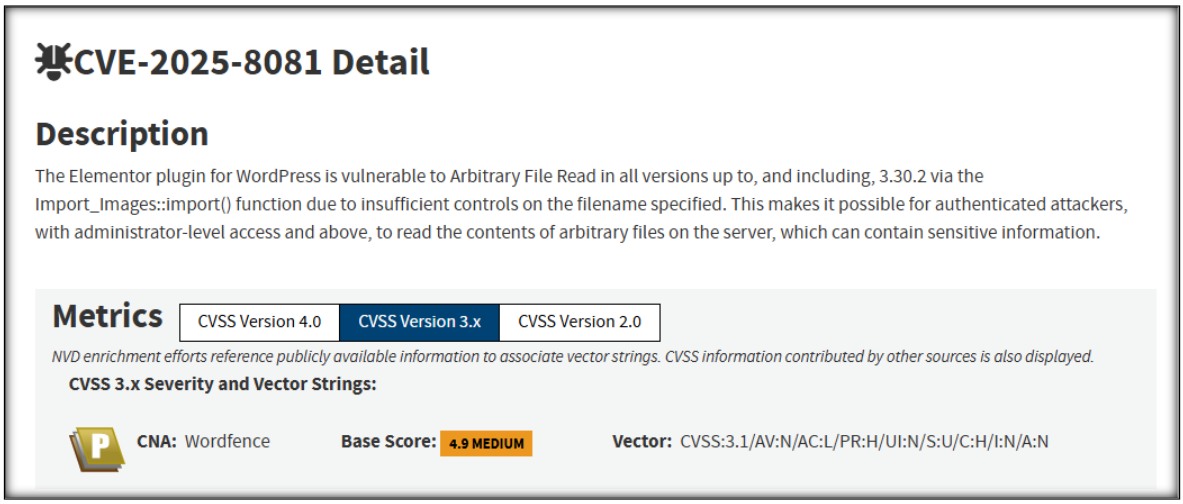
عدم بروز رسانی قالب و افزونه‌های مورد استفاده در سیستم مدیریت محتوای سامانه منجر افزایش احتمال نفوذ می‌گردد. پس از بررسی صورت گرفته نسخه‌های آسیب‌پذیر شناسایی شده به شرح زیر می‌باشد:

در آزمون‌های نفوذ صورت گرفته مشخص گردید سامانه هدف به علت عدم بروزرسانی افزونه‌های خود دارای آسیب‌پذیری به شماره CVE-2025-4566 می‌باشد که منجر به آسیب‌پذیری XSS از نوع Stored می‌گردد.









راهکار پیشنهادی:

- استفاده از آخرین نسخه انتشار یافته
- استفاده از بروزرسانی خودکار
- استفاده از نسخه original قالب و افزونه‌ها

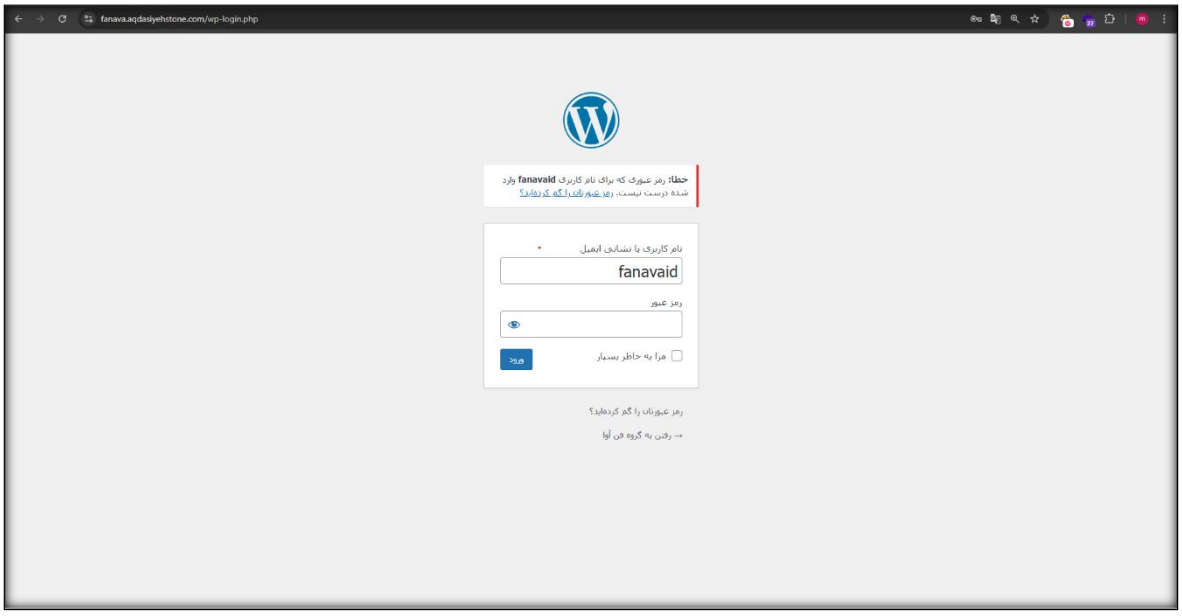
2-2- آسیب‌پذیری Account Enumeration and Guessable User Account

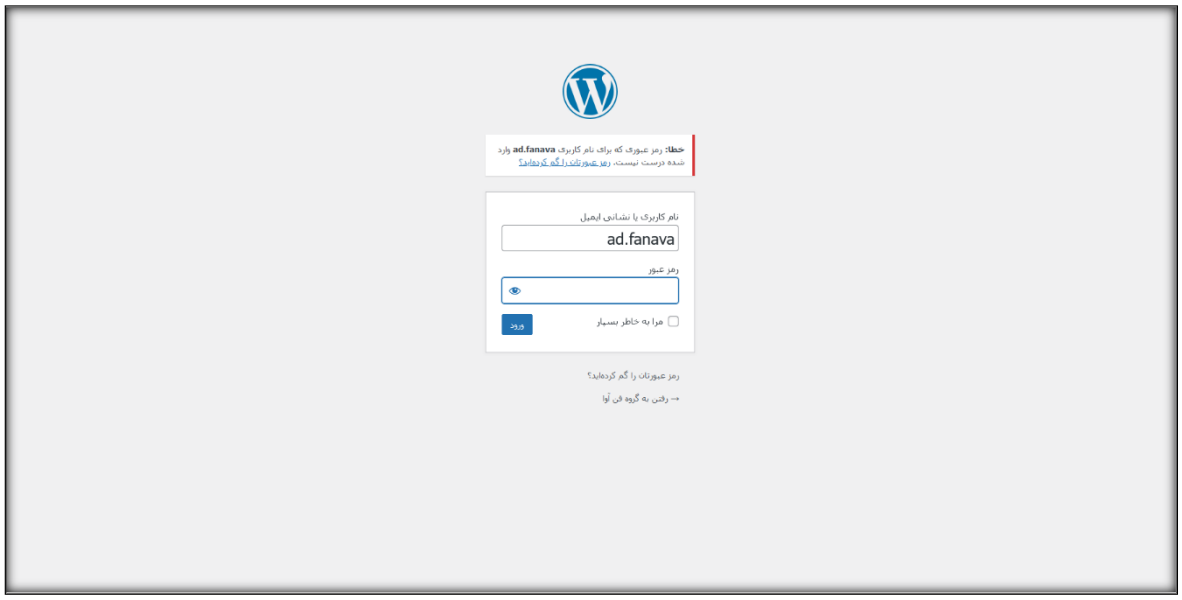
در این آزمون مشخص می‌شود که آیا امکان جمع‌آوری نام‌های کاربری موجود در سامانه در طی فرآیند احرازهویت وجود دارد یا خیر. نتایج مربوط به این بخش در انجام حملات Brute Force مورد استفاده قرار می‌گیرد؛ به‌گونه‌ای که با در دست داشتن نام‌های کاربری صحیح، نفوذگر می‌تواند اقدام به پیدا کردن کلمه عبور متناظر با آن نماید.

اغلب وب‌اپلیکشن‌ها بر اثر خطا در طراحی و یا به‌صورت هدفمند، وجود یا عدم وجود یک نام‌کاربری در پایگاه‌داده را فاش می‌کنند. به عنوان نمونه، زمانی که نام‌کاربری اشتباه باشد، پیغام خطای متفاوتی نسبت به زمانی که نام کاربری صحیح است ولی رمزعبور اشتباه است، به کاربر نشان داده می‌شود. این موارد جهت جمع‌آوری اطلاعات، بررسی وجود یک کاربر خاص روی سامانه و در نهایت اقدام به انجام Brute Force و بدست آوردن کلمه عبور، مفید است.

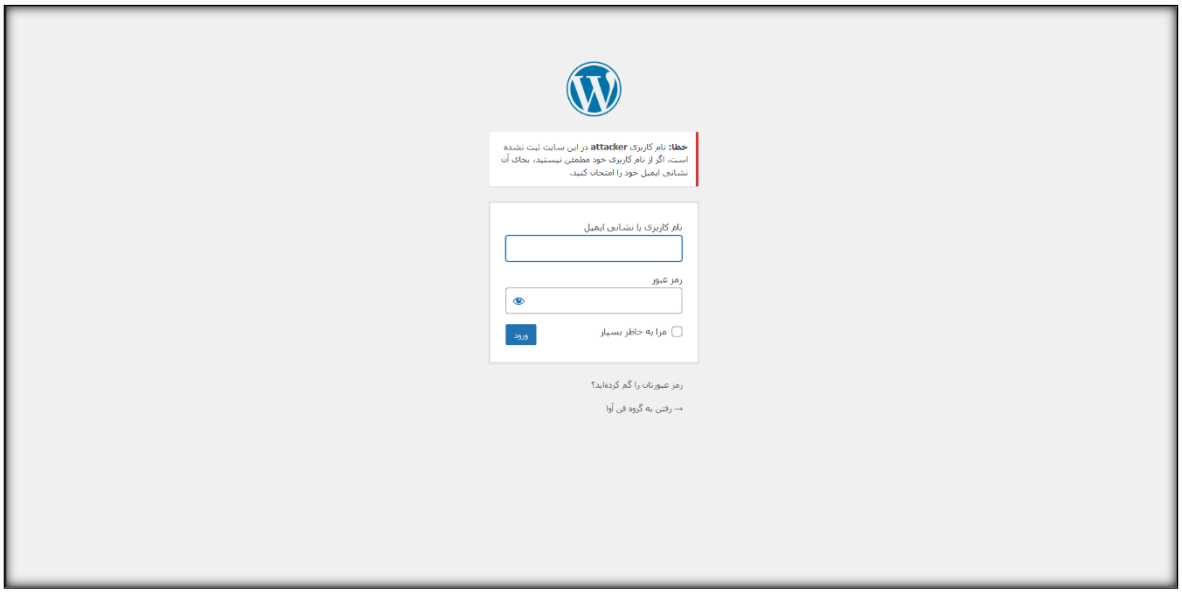
در این سامانه و با توجه به دریافت پیام‌های خطای متفاوت هنگام وارد کردن نام کاربری صحیح و نادرست، امکان استخراج نام‌های کاربری وجود داشت. در جریان تست ما دو حساب کاربری با شناسه‌های fanavaid و ad.fanava شناسایی شد که این موضوع نشان‌دهنده آسیب‌پذیری در مکانیزم مدیریت خطا و اطلاع‌رسانی است و می‌تواند منجر به افشای لیست کاربران سیستم شود.

هنگامی که نام کاربری به صورت صحیح وارد شده باشد پیامی که در تصویر مشخص شده است نشان داده می‌شود:

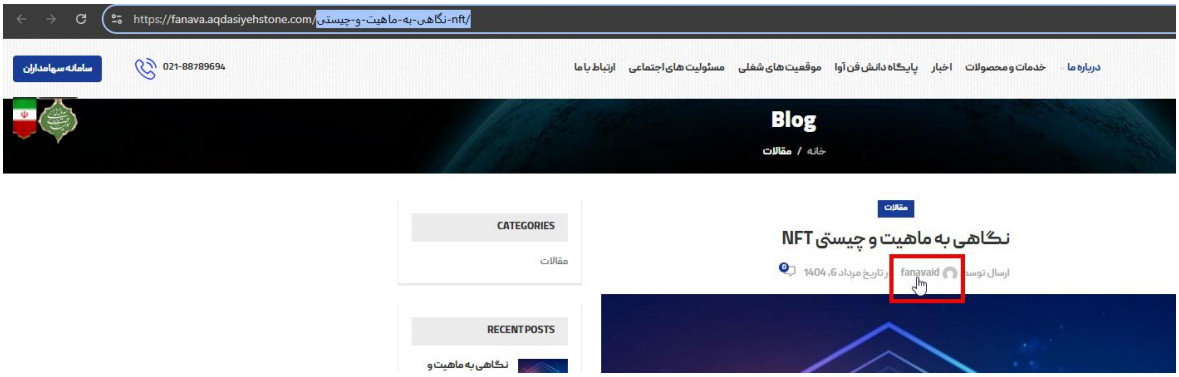




در صورت وارد نمودن نام کاربری نادرست، پیامی که در تصویر مشخص شده است نشان داده می‌شود:



روش دوم: مشخص گردید در صفحه اخبار سامانه، نام کاربری کامل مدیر سایت قابل رویت می‌باشد.



روش سوم: در بررسی بیشتر مشخص گردید در صورت اینکه پارامتر با مقدار 1=author? را در ادرس اصلی سایت اضافه کنیم، سامانه در پاسخ به درخواست ارسالی صفحه را به صفحه نام کاربری مدیر هدایت می‌کند.

```
C:\Users\one>curl -x "http://127.0.0.1:10809" -I "https://fanava.aqdasiyehstone.com/?author=1" -H "Cookie: wp-wpml_curre
nt_language=fa; wordpress_test_cookie=WP%20Cookie%20check; webmailsession=%3aW6OCjLcRL_3Uyl81%2c2a39ed1c10f23bcb7ce2ad80
12bb7826; roundcube_cookies=enabled; timezone=undefined"
HTTP/1.1 200 Connection established

HTTP/1.1 301 Moved Permanently
Alt-Svc: h3=":60413"; ma=2592000,h3=":60414"; ma=2592000,h3=":60418"; ma=2592000
Cache-Control: public, max-age=0
Content-Type: text/html; charset=UTF-8
Date: Mon, 22 Sep 2025 10:01:04 GMT
Expires: Mon, 22 Sep 2025 10:01:04 GMT
Location: https://fanava.aqdasiyehstone.com/author/fanavaid/
Server: BitNinja-Waf3
Server: LiteSpeed
Vary: Accept-Encoding
X-Redirect-By: WordPress
X-Turbo-Charged-By: LiteSpeed
```

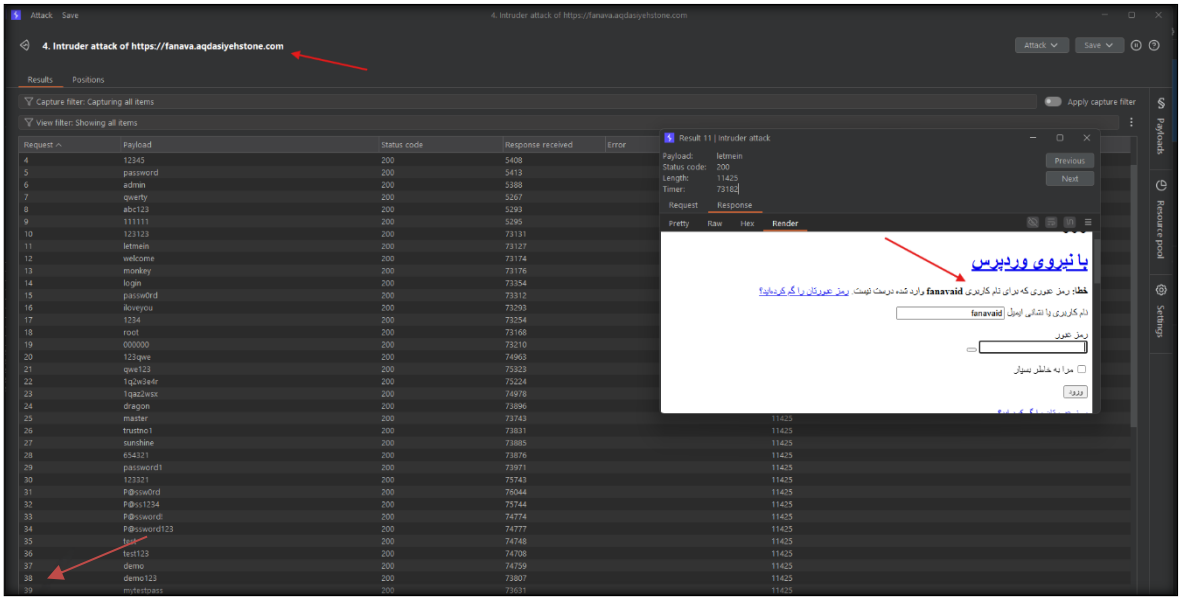
راهکار پیشنهادی

توصیه می‌شود در صورت امکان، با مدیریت صحیح خطاهای نمایشی، از نمایش خطاهای مربوط به عدم وجود کاربر که منجر به توانایی نفوذگر در شناسایی حساب‌های کاربری می‌شود، اجتناب گردد. همچنین در صورت ورود نام کاربری صحیح یا نادرست، پیام خطای یکسانی به کاربر نمایش داده شود.

2-3- آسیب‌پذیری Weak Lock Out Mechanism

یکی از حملاتی که نفوذگران در اکثر سامانه‌ها به خصوص سامانه‌های وب از آن استفاده می‌کنند، حمله Brute Force می‌باشد. در این حمله نفوذگر با استفاده لیست کلمات عبور پرکاربردی که در اختیار دارد، اقدام به تست آن‌ها به عنوان کلمات عبور سامانه می‌کند. در صورت موفقیت آمیز بودن این حمله، نفوذگر می‌تواند به سامانه وارد شود. به همین منظور باید مکانیزم‌های جلوگیری از چنین حملاتی در سامانه قرار داده شود. علاوه بر استفاده از عبارت CAPTCHA می‌بایست ساختاری برای مسدود سازی حساب‌هایی که تلاش‌های ناموفق برای ورود به سامانه دارند نیز در نظر گرفته شود.

با توجه به بررسی‌های صورت‌گرفته، کلمات عبور نادرست متعددی برای یکی از حساب‌های کاربری سامانه ارسال شده است، اما هیچ‌گونه فرآیندی به‌منظور مسدودسازی کاربر اعمال نشده است. این موضوع به کاربر غیرمجاز اجازه می‌دهد تعداد زیادی از کلمات عبور را برای ورود به سامانه بررسی کند.



راهکار پیشنهادی

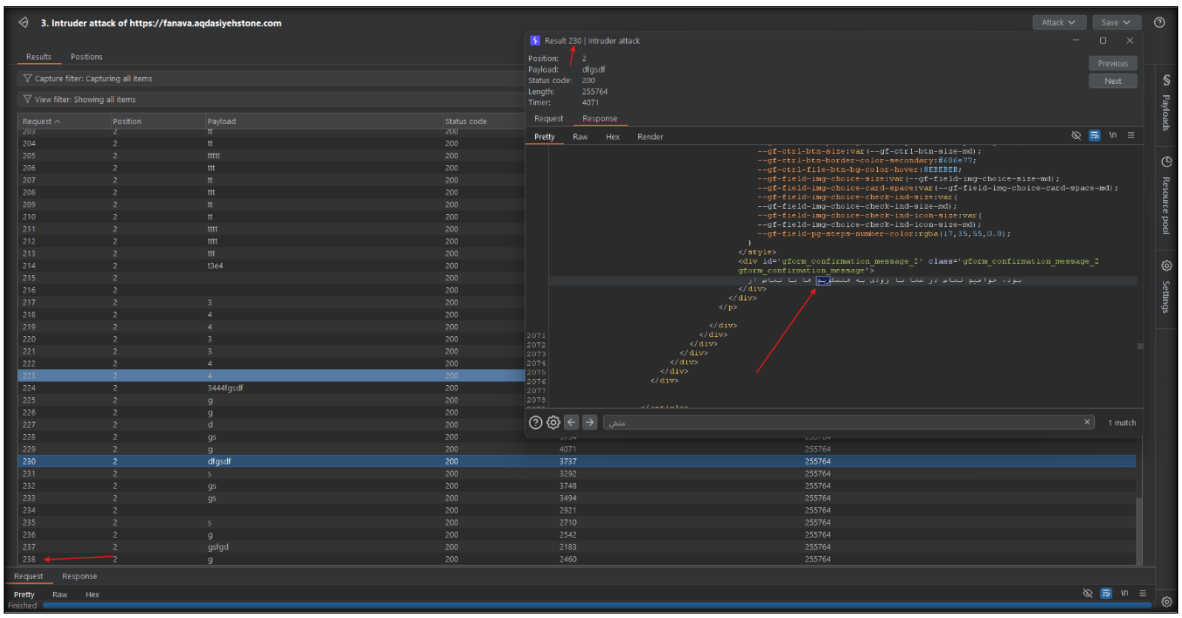
به منظور رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا فرآیندی به منظور مسدودسازی حساب کاربری با تعداد تلاش ناموفق مشخص (10 تلاش ناموفق) ایجاد گردد. همچنین مقدار CAPTCHA استفاده شده در سامانه سمت سرور نیز بررسی شده و با هر بار ارسال درخواست، مقدار آن تغییر پیدا کند.

2-4- آسیب‌پذیری Bypass Rate Limit

حد مجاز به حداکثر تعداد دفعاتی که یک کاربر یا سیستم می‌تواند یک عمل خاص را در یک دوره زمانی مشخص انجام دهد، rate limit گفته می‌شود. این یک مکانیزم رایج برای کنترل حجم ترافیک به یک سرویس وب یاAPI است تا از بارگذاری بیش از حد سیستم جلوگیری کند و استفاده منصفانه را تضمین نماید. به عنوان مثال، ممکن است یک وب‌سایت به شما اجازه دهد تا حداکثر 100 درخواست در ساعت به سرور خود ارسال کنید. اگر از این حد مجاز فراتر بروید، ممکن است موقتا تا زمانی که حد مجاز بازنشانی مسدود گردد و پیام خطا دریافت کند.

حد مجاز برای حفظ پایداری و عملکرد خدمات آنلاین ضروری است. این مکانیزم کمک می‌کند تا از سوءاستفاده‌هایی مانند اسپمینگ یا فعالیت‌های مخرب جلوگیری شود و منابع برای همه کاربران در دسترس باشد.

در بررسی‌های انجام شده مشخص گردید که مکانیزم Rate Limiting در بخش ثبت نظرات سایت به‌درستی پیاده‌سازی نشده است. این موضوع به مهاجم این امکان را می‌دهد که بدون محدودیت و در بازه‌های زمانی کوتاه، تعداد زیادی نظر مخرب یا غیرمجاز را ثبت کند. نداشتن محدودیت مناسب می‌تواند منجر به ایجاد بار اضافی روی سرور، افزایش حجم پایگاه داده و کاهش کارایی سامانه شود و در مواردی ممکن است باعث اختلال در عملکرد سایت یا بهره‌برداری سوء از منابع سرور گردد. همچنین، این ضعف می‌تواند در سناریوهای پیشرفته‌تر، به تشویق کاربران به ارسال اسپم و یا تخریب تجربه کاربری دیگران منجر شود.



همچنین در بخش ثبت نظر در اخبار سایت و نداشتن مکانیزم امنیتی از جمله Captcha این بخش نیز آسیب‌پذیر می‌باشد.



راهکار پیشنهادی

برای رفع آسیب‌پذیری پیشنهاد می‌شود:

- محدود کردن تعداد درخواست‌ها :کاهش تعداد درخواست‌ها به سرور یا API با بهینه‌سازی کد و تجمیع درخواست‌ها.
- استفاده از Captcha
- استفاده از حافظه کش :ذخیره داده‌های پرکاربرد در حافظه کش محلی به‌جای درخواست مکرر به سرور.
- کنترل زمان‌بندی درخواست‌ها :تنظیم زمان‌بندی درخواست‌ها به‌طوری‌که در زمان کوتاه تعداد زیادی درخواست ارسال نشود.
- استفاده از سربارهای مختلف :در صورت امکان، استفاده از سرویس‌های جانبی برای توزیع درخواست‌ها به سرورهای مختلف.
- پایش و مانیتورینگ :نظارت بر تعداد و الگوی درخواست‌ها به‌منظور شناسایی نقاط ضعف و بهبود عملکرد.

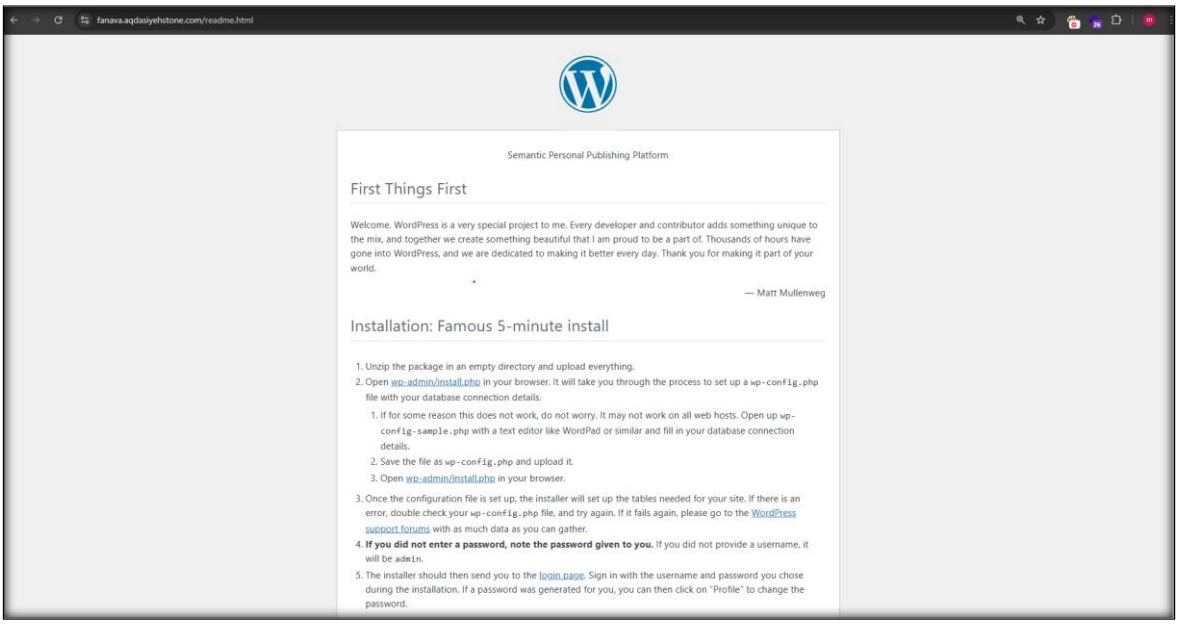
۲-۵- آسیب‌پذیری WordPress Default Page

سیستم مدیریت محتوای وردپرس (WordPress) به‌صورت پیش‌فرض پس از نصب، شامل یک صفحه نمونه (Sample Page / Default Page)می‌باشد. باقی ماندن این صفحه روی وب‌سایت بدون حذف یا تغییر، به‌طور مستقیم آسیب‌پذیری بحرانی محسوب نمی‌شود اما می‌تواند به‌عنوان یک مشکل امنیتی از نوع افشای اطلاعات (Information Disclosure) در نظر گرفته شود. وجود این صفحه به مهاجمان کمک می‌کند تا:

- از استفاده وب‌سایت از وردپرس اطمینان حاصل کنند.
- ساختار و نسخه احتمالی وردپرس را تشخیص دهند.
- نقطه شروعی برای شناسایی و سوءاستفاده از آسیب‌پذیری‌های شناخته‌شده وردپرس به‌دست آورند.

طبق بررسی‌های صورت‌گرفته بر روی سامانه موردنظر، مشاهده شد که صفحه پیش‌فرض وردپرس همچنان در دسترس عموم قرار دارد. این موضوع می‌تواند اطلاعات غیرضروری را در اختیار مهاجمان قرار دهد و احتمال هدف‌گیری وب‌سایت در حملات مبتنی بر CMS وردپرس را افزایش دهد.

در تصویر زیر، صفحه پیش‌فرض وردپرس که در سامانه موردنظر شناسایی شده است، قابل مشاهده می‌باشد.



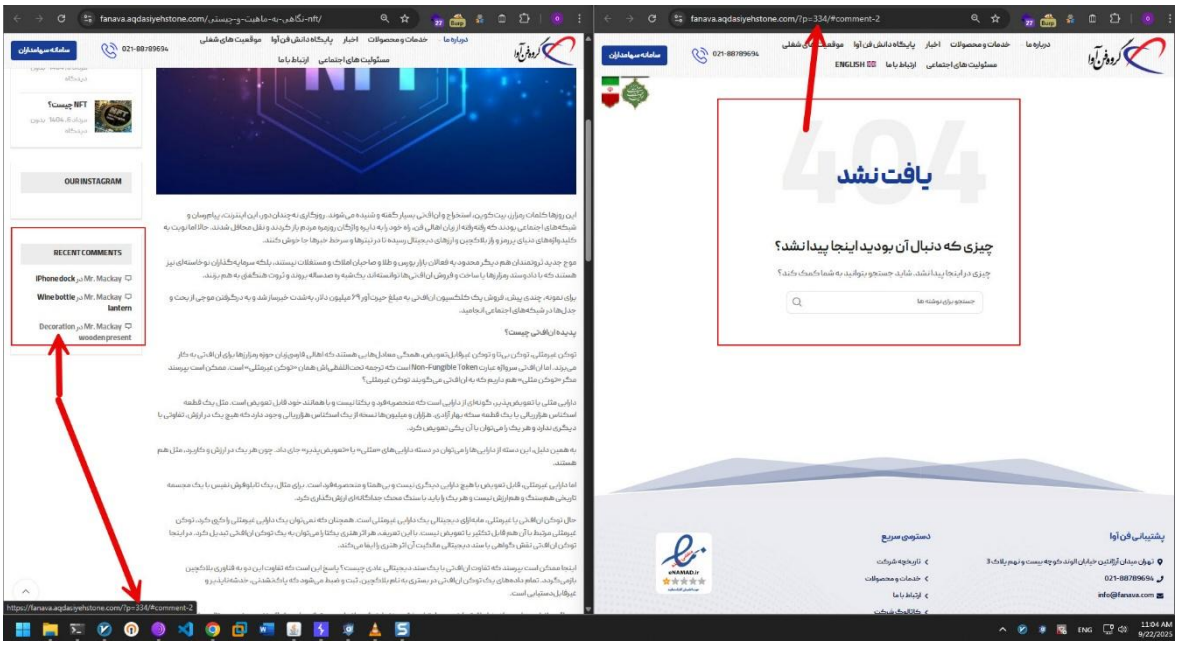
راهکار پیشنهادی

- حذف صفحه پیش‌فرض و صفحات نمونه پس از نصب وردپرس.
- بررسی و حذف هرگونه فایل یا صفحه غیرضروری.
- اطمینان از سخت‌سازی (Hardening) وردپرس مطابق با بهترین رویه‌های امنیتی.

2-6- آسیب‌پذیری Information Disclosure

آسیب‌پذیری Information Disclosure یا افشای اطلاعات به حالتی گفته می‌شود که در آن یک سیستم به طور غیرمجاز اطلاعاتی را که نباید فاش شود، به فردی که مجاز به دسترسی به آن نیست، نشان می‌دهد. این اطلاعات می‌تواند شامل جزئیات حساس مانند پیکربندی سرور، مسیرهای فایل، پیغام‌های خطا، یا اطلاعات مرتبط با سیستم باشد که می‌تواند برای حمله‌کنندگان مفید واقع شود.

در بررسی‌های صورت گرفته مشخص گردید سامانه هدف نظرات پست‌هایی که حذف شده اند را در منوی نظرات تازه در سمت چپ اخبار به نمایش گذاشته است که این یک نوع نشت در سطح پایین به حساب می‌آید.



راهکار پیشنهادی

به جهت رفع آسیب‌پذیری موجود پیشنهاد می‌گردد در زمان حذف پست و یا خبر مورد نظر نظرات نیز به همراه آن حذف شوند تا در صورت لزوم به حذف یک خبر اشتباه نظرات آن برای دیگر کاربران به نمایش گذاشته نشود.

2-7- عدم استفاده از Security Headers

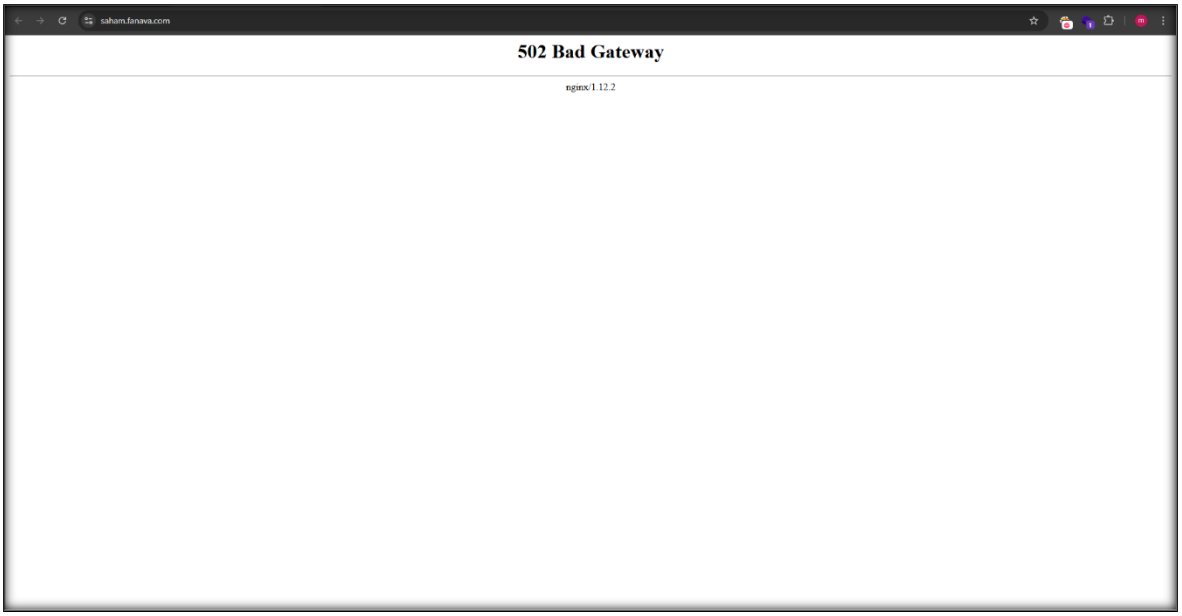
در بررسی‌های اولیه مشخص گردید سامانه هدف از بعضی از هدرهای امنیتی استفاده نمی‌کند.

```
[SECURITY HEADERS]
[FAILD] X-Frame-Options
[FAILD] X-XSS-Protection
[FOUND] Cache-Control : public, max-age=0
[FAILD] X-Content-Type-Options
[FAILD] Strict-Transport-Security
[FAILD] Content-Security-Policy
[FOUND] Target have Browser Cache Weakness
```

Nginx Version Disclosure-2-7-1

در مرحله جمع آوری اطلاعات، در صورت شناسایی نسخه مربوط به سرور وب و همچنین زبان برنامه نویسی سامانه، این امکان وجود دارد که با بررسی آسیب‌پذیری‌های موجود در نسخه جاری وب سرور و برنامه تحت وب، آسیب‌پذیری‌های مربوط به آن شناسایی شده و در جهت وارد نمودن آسیب به برنامه از آن‌ها بهره برداری شود. به همین دلیل، مخفی نمودن نسخه سرور وب و برنامه تحت وب، روشی به منظور پیشگیری از خطرات مذکور را فراهم می‌کند.

نسخه مربوط به سرور وب Nginx در ساب‌دامنه سامانه به آدرس https://saham.fanava.com ، قابل مشاهده می‌باشد:



راهکار پیشنهادی

پیشنهاد می‌شود جهت رفع این آسیب‌پذیری، در فایل پیکربندی وب سرور (nginx.conf) مقدار زیر را در قسمت Basic Setting اضافه نموده و وب سرور را ریستارت نمایید:

server_tokens off;